

KC桌面——外资精译

Bernstein：2026年中CISO电话会议纪要-预算趋势、优先级及AI影响

我们近期举办了一场电话会议，邀请了三位首席信息安全官（CISO）讨论最新的预算趋势、AI影响及优先级。以下是完整的编辑版纪要，重播链接在此。

网络安全支出持续超过整体IT支出，主要驱动力是AI。安全负责人一致将AI描述为新研究的最大催化剂，原因在于组织既要防御AI驱动的攻击，也需要安全地支持内部AI应用。

身份已成为新的安全边界，非人类身份现已成为首要关注点。焦点正转向保护AI代理（含人工审核及自主型）——如何为数据/系统/应用访问分配身份，并应用特权访问和治理框架，确保人类与非人类主体均遵循最小权限、有时限的访问原则。

组织在AI采用与控制及可见性之间难以平衡。安全负责人报告称，员工在多个大语言模型上的实验急剧增加，引发了对以下问题的担忧：哪些数据被输入模型、代理可访问哪些系统、可执行哪些操作，以及这些操作如何被监控和审计。因此，组织正通过集中式AI路由器或端点、网络及数据层控制来研究AI治理，以提供对提示词、代理行为、数据访问及潜在数据外泄不确定性的可见性。

除预算增加外，供应商整合是支撑新安全优先级的主要资金来源。CISO们正在淘汰遗留平台，重新评估现有安全堆栈，并倾向于从现有供应商处增加功能，因为这通常比添加同类最佳独立产品便宜得多。……但供应商整合发生在关键网络安全支柱层面，而非端到端。与会者普遍倾向于在“核心支柱”（如身份、端点、网络、Web安全、云安全和电子邮件）内维持专用领导者。CrowdStrike、Wiz、Palo Alto和Okta因创新而频繁受到赞誉。

安全运营正朝着自动化方向发展，因为人工速度的响应已不再足够。与会者一致认为，AI驱动的攻击者正在加速威胁节奏，迫使组织积极评估代理型SOC平台和自主响应能力，以减少调查时间、提升韧性，并更接近机器速度运行。由风投支持的“瑞士”式初创公司（如Torq、Tines）能够跨网络安全支柱进行整合，似乎更受青睐。讨论还表明，传统SIEM相对于代理型ITDR/SOC模式正变得不那么具有战略意义。

讨论传递的核心信息是，AI正迫使网络安全战略重新设计。预算编制、身份管理、安全运营、供应商选择、治理和不确定性管理，都在通过AI视角被重新评估。安全负责人不再将AI视为新兴趋势；他们正围绕“AI将定义未来威胁格局和未来技术环境”这一假设来重构安全项目。

BERNSTEIN公司代码表

O - 跑赢大盘，M - 与大盘持平，U - 跑输大盘，NR - 未评级，CS - 暂停覆盖

CRWD、OKTA、S的基准年为2026年

来源：彭博、Bernstein估计与分析。

观察提示：公司情况更新

。

详细内容：公司情况更新

我们近期举办了一场电话会议，邀请了来自三个不同行业（保险、制造和医疗软件）的三位CISO，分享他们对网络安全支出的看法。本报告总结了我们的关键发现，并附有完整的编辑版纪要，会议重播可通过此链接获取

。

关于我们近期CISO调查的完整结果，请查看此链接。

详细要点：公司情况更新

网络安全支出持续超过整体IT支出，主要驱动力是AI。在各行业中，安全预算要么增长速度超过整体IT预算，要么在其他IT职能面临削减时得到保护。安全负责人一致将AI描述为新研究的最大催化剂，原因在于组织既要防御AI驱动的攻击，也需要安全地支持内部AI应用。

身份已成为新的安全边界，非人类身份现已成为首要关注点。CISO们强调，远程办公、AI代理和自主工作流已从根本上改变了访问管理需求。焦点正从员工/客户账户转向独立AI代理的身份——如何为数据/系统/应用访问分配身份，并应用特权访问和治理框架，确保人类与非人类主体均遵循最小权限、有时限的访问原则。

组织在AI采用与控制及可见性之间难以平衡。AI在工程和业务团队中的使用正在快速增长，速度往往超出预期。安全负责人报告称，令牌消耗急剧增加，员工在多个大语言模型上的实验增多，对以下问题的担忧日益加剧：哪些数据被输入模型、代理可访问哪些系统、可执行哪些操作，以及这些操作如何被监控和审计。因此，组织正通过集中式AI路由器或端点、网络及数据层控制来研究AI治理，以提供对提示词、代理行为、数据访问及潜在数据外泄不确定性的可见性。讨论的重点并非限制AI使用，而是围绕数据保护、访问权限和代理自主性建立护栏。

特别是在预算受限的环境中，CISO们正在淘汰遗留平台，重新评估现有安全堆栈，并倾向于从现有供应商处增加功能，因为这通常比添加同类最佳独立产品便宜得多。他们并非购买独立的点解决方案，而是在可能的情况下从现有战略供应商处增加功能，因为附加模块通常比引入新产品便宜得多。目标是释放资源用于更高优先级的项目。

供应商整合发生在关键网络安全支柱层面，而非端到端。尽管微软和Palo Alto等公司继续扩展其安全产品组合，但与会者普遍倾向于在“核心支柱”（如身份、端点、网络、Web安全、云安全和电子邮件）内维持专用领导者。CrowdStrike、Wiz、Palo Alto和Okta因创新而频繁受到赞誉，而一些在AI和现代身份需求方面进展较慢的供应商则引发了担忧。

与会者一致认为，借助人工智能的攻击者正在加速威胁的演变，使得传统的安全运营中心模式越来越难以为继。各组织正在积极评估智能体SOC平台和自主响应能力，以缩短调查时间、提升韧性，并尽可能以机器速度运行——那些能够跨网络安全支柱进行全局审视的“瑞士”初创公司似乎更受青睐。讨论还指出，传统的SIEM正逐渐失去战略地位，而集成了威胁检测、威胁情报、编排和响应能力、能将信号转化为行动的综合方案则变得更为重要。最终形态越来越趋向于一种智能体ITDR/SOC模式，该模式将检测、丰富、调查、优先级排序和响应整合到一个高度自动化的工作流中。

讨论传递的核心信息是，人工智能正在迫使网络安全战略进行重新设计。预算、身份管理、安全运营、供应商选择、治理和不确定性管理，所有这些都在通过人工智能的视角被重新评估。安全领导者不再将人工智能视为一种新兴趋势；他们正在围绕“人工智能将定义未来威胁格局和未来技术环境”这一假设来重构安全计划。

完整对话记录

本记录为清晰和连贯起见已做编辑。

发言人标识：公司情况更新

Bernstein分析师：PW：Peter Weed（美国中小型软件股）

CIO：Sean（保险业）；Kristie（制造业）；Raj（医疗软件）

PW：大家早上好。我们大概再等30秒，让与会者陆续加入。我知道连接所有设备需要一点时间。请稍候。好了，我想我们可以开始了，希望所有人都已成功连接。

先简单说几点注意事项。提醒一下，加入会议的各位可以通过Pigeonhole链接提交问题，请随时提问。如您所知，我们会举办一系列此类网络研讨会。显然，我们刚刚举办了一场关于CIO的研讨会。我请今天的小组成员关闭视频，因为我们讨论的网络安全话题可能稍微敏感一些。

我想首先快速回顾一下我们进行的CISO调查。然后我会介绍小组成员，并请他们分享一些经验。希望你们中的许多人，如果不是大多数的话，已经在本周早些时候看到了我们发布的100位CISO调查结果，这是我们每半年进行一次调查。这是年中调查，主要聚焦于美国的网络安全从业者。

主要发现是什么？毫不意外，这与我们在CIO调查中看到的情况非常一致：CIO们预算增长最多的项目是什么？是网络安全。在网络安全领域，我们从网络安全专业人士那里听到了什么？我们听到，他们的预算总体上在增加，而且平均增幅高于IT预算。

事实上，纵观我们收到的所有回复，预算增幅平均在4%到6%以上，具体取决于行业。但这呈现出一个钟形曲线。有些组织的预算增幅高达百分之十几，而有些则只有较低的低位数增幅。

从主题角度来看，我认为同样不令人意外的是，推动这股热潮的很大一部分因素是人工智能，既包括来自攻击方的威胁，也包括其组织内部为保障业务部门正在推进的项目（尤其是人工智能项目）安全而产生的需求。

显然，我们完整的报告中有很多细微的细节。当我们审视其中获得研究的网络安全细分领域时，某些领域的研究远高于其他领域，这暗示这些领域可能是人们围绕这些威胁进行研究以及支持相关基础设施的地方。

这包括我认为大家讨论很多的几个主题领域。身份安全是重中之重。其他一些领域，如端点安全、威胁情报，也持续位居前列。

但非常有趣的是，我们看到变化很大的一个领域是安全运营本身。至少根据我的个人经验，网络安全中的人力成本可能占到预算的40%。这些领域既需要更多的专业知识，也可能需要引入工具来辅助组织。我认为这将是我们与今天与会者进行的一些有趣对话。

另一方面，表现持续不佳的领域，其中最差的是安全服务边缘。同样，我认为听听今天参会的CISO们的看法会很有趣，了解为什么会出现这种情况，以及它为何目前不是优先事项。我不认为这意味着人们正在淘汰这些技术。只是相对于其他可以做的事情，它目前不是最受关注的话题。

其他研究较低的领域包括SIEM。这里指的是更传统的SIEM，比如Splunk正在做的事情，而不是我心目中更偏向威胁情报的领域，即下一代SIEM或XIM，或者你们从其他一些供应商那里听到的类似概念。至少在我看来，邮件安全、安全浏览器等也是目前研究关注度较低的领域。

好了，背景介绍就到这里……再次提醒，请查阅CISO调查报告。如果还有其他问题，欢迎在本次对话中提出。接下来，我想请今天的小组成员依次介绍他们的组织。显然，他们不会透露公司名称，但会介绍他们所处的行业、组织规模以及网络安全预算的大致情况。

肖恩，因为我在屏幕上先看到你，所以请你先来。请简单介绍一下你的组织背景：所处行业、预算规模，并帮助我们了解今年的预算变化情况。是什么真正推动了这种变化？优先事项发生了怎样的变化？你们把资金投入到了哪些领域？

Sean：好的，大家好。我来自商业保险行业。我们全球约有6000名员工，其中绝大多数是远程办公。我们今年的重点是，可能会将安全支出增加12%到15%。

我们一直在使用传统的端点安全服务，正如Peter所说，还有很多SIEM、邮件安全方面的东西。但现在，我们真正将重心转向了人工智能领域。显然，我们越来越多的用户正在使用这些工具。我相信这在各行各业都是如此。我们正试图更深入地了解他们如何使用这些工具，以及威胁向量来自何处。这些威胁似乎每天都在变化。

我们正在努力思考这些额外资金将投向何处。我们正在与几家不同的潜在供应商洽谈，看看哪些方案适合我们的部署。我们的部署方式因服务客户的不同而多种多样，因此没有一刀切的方案。我们必须更加灵活，我认为这对我们来说是一个挑战，但我们的安全支出确实在增长，增幅达到两位数，不过主要聚焦在人工智能领域。您已静音。

PW：我确实静音了。我这是在防止自己胡言乱语打扰到各位。请再介绍一下贵组织的规模。

Sean：我们在全球约有5500名员工。

PW：好的。Kristie，同样的问题问您，请简单介绍一节奏变化背景，以及您的优先事项和预算发生了怎样的变化。

Kristie：好的。是的，我身处制造业。我所在的公司约有5万名员工，分布在29个国家的170个地点，因此我们的全球足迹相当大。欧洲出台的许多新法规推动了我们正在进行的许多合规活动。我们的行业，即全球制造业，始终承受着巨大的成本不确定性。因此，我们被要求努力维持预算持平直至2027年。考虑到业务部门正大力推动人工智能的应用，这变得有些挑战性。

我们需要研究的两个领域是：更好的内部数据分类、基于角色的访问控制、最小权限原则的执行，因为我们在环境中添加了新的语言模型，以确保不会过度暴露内部数据。其次，随着非人类身份的激增，我们需要构建身份治理与管理（IGA），以确保我们能够妥善管理这些身份，避免出现代理身份采取超出其权限范围的行为。

PW：谢谢，Kristie。Raj，同样的问题问您。

Raj：各位，早上好、下午好、晚上好，无论您身在何处。我是Raj，一家医疗数据分析公司的首席信息安全官。我们主要立足美国市场，但在全球设有研发中心。我们总员工人数大约在12000到15000之间。营收规模大约在20亿到50亿美元之间。

我2026年的网络安全预算约为2000万美元，大约占整体IT预算的10%到12%。进入2026年，主要焦点仍然是保障内部人工智能计划的安全，以及为应对我们看到的新兴人工智能攻击性威胁和能力设置控制措施。

我想说，从2025年到2026年，我的整体网络安全预算预计增长约6%到7%，这多年来算是相当正常的，但今年三月，随着关于Mythos大语言模型、先进前沿模型及其攻击能力的各种披露，我们确实不得不重新校准和评估相关事项。因此，我得以回到领导层和董事会面前，请求额外资金来缓解其中一些威胁。

所以，目前来看，我预计2026年的网络安全预算最终将比上一年增加20%。这些研究大部分集中在攻击面缩减上。我们听到了很多关于Mythos和一些前沿模型能做什么的消息，我们真的不想冒险。我们希望通过减少攻击面、降低技术债务，确保自身尽可能安全。

其次，我们在身份管理方面加速推进了许多项目，特别是随着代理型人工智能在公司内外得到更多采用，围绕非人类身份的管理项目。第三，我认为我们关注的是业务韧性。因为归根结底，我们假设网络事件会发生，而关键在于我们能多快从中恢复并进入运营状态。

PW：谢谢，Raj。也许我们可以就此继续讨论，因为你提到了因担忧而带来的显著预算增长。这是如何运作的？你是去找首席信息官吗？还是需要越过首席信息官？是什么论据让大家达成一致的？

另外，据你所知，这笔预算从何而来？首席信息官是否需要其他领域削减开支，而他的总预算保持不变？这完全是新增资金吗？他们在多大程度上推动你提高效率，比如淘汰一些遗留架构、整合供应商，或者需要调整人员规模，以便你能负担得起更多技术？这些资金是如何落实的？

Raj：当然。我认为在这种特定情况下，当我们开始评估这些前沿攻击模型及其攻击能力所带来的不断演变的威胁时，我们立即审视了自身的暴露面。我们是医疗行业，处理大量医疗数据、受保护健康信息（PHI），处于高度监管的环境中。因此，我进行了一次不确定性评估，确定了我们需要补救或加速不确定性降低的关键领域。

在这个过程中，真正帮助到我的一点是，我们确实使用了一种合理的不确定性量化方法。因此，我能够以美元金额来估算某个特定事件或情况可能给公司带来的成本。基于所有这些评估，我们不得不一直上报到董事会，在他们面前陈述我们的理由，说，好的，这是我们想要加速推进并优先处理的计划，这是从预算角度来看所需的成本。

期间有过一些讨论，但我认为真正有帮助的是媒体上关于这些先进攻击能力的各种讨论。因此，董事会非常支持，我们得以获得额外资金。所以，回答你的问题，Peter，这些是董事会鉴于新兴威胁而批准的新增资金。

PW：是的。过去几天你得到了更多帮助，因为OpenAI和Sol建立了一个相当脆弱的容器化应用程序，只是为了证明他们能够突破一个不安全的系统。

Kristie, 如果我没听错的话, 我认为你的情况不同, 那就是你面临很大不确定性, 不能让预算增长速度超出正常水平, 不像Raj, 他原本有6%的增长预算, 然后还能争取到更多资金。在你们组织内部, 这种对话有何不同?

Kristie: 是的。我认为, 总体而言, 中央服务部门面临着很大的不确定性, 需要为业务降低成本。这会削减我们销售产品的利润。当前全球环境非常艰难, 关税等因素影响着我们产品的单价。

因此, 其余业务部门普遍严重依赖中央服务部门进行全面削减, 这影响了我们的支出和增长能力。我很希望能实现……6% 的增长就很不错了, 20% 更是惊人, 但在公司当前的财务环境下, 这确实不现实。

PW: 不过, 这很有意思。如果中央服务部门确实被要求收紧预算……我理解这意味着其预算占总营收的比例可能正在下降, 但你的预算在某种程度上却能保持更稳定。我猜你的预算有所增加。你的预算占整体IT支出的比例是在上升, 还是保持稳定?

Kristie: 问得好。整体IT预算被要求削减10%。我的预算将保持持平, 但我只占整体IT预算的约6%。这至少让我离Gartner指标中合理的整体IT支出水平更近了一点。不过, 我还负责IT制造和嵌入式产品的网络安全, 这包括面向客户的产品。如何确保这些产品的安全, 也包含在该预算中。

PW: 当你考虑这笔预算时, 我可以想象网络安全的某些部分几乎像是成本中心, 因为它们用于内部运营。而你负责的面向客户的部分, 几乎属于产品团队, 因此它会随着业务规模而扩展。你在这两种预算——内部面向与客户面向——上是否面临不同的不确定性?

Kristie: 是的, 确实如此。我认为更多是在嵌入式产品方面, 网络安全实际上关乎我们使用的加密技术、我们在全球制造工厂购买和安装的HSM (硬件安全模块)。因此, 很多问题归结为技术不确定性: 我们能否做得更便宜? 能否使用更多开源方案? 能否在低成本国家构建? 能否使用低成本劳动力来降低对单件成本的整体影响?

但一旦以这种方式建立起来, 一旦基础设施建成, 就很容易证明将成本转嫁是合理的……我们是一级供应商, 所以向客户转嫁成本对我们来说相当容易。

PW: 在这种更受限的环境中, 你的预算将相当稳定, 但你谈到了优先事项的变化, 你如何重新分配预算来投入这些新议题?

Kristie: 是的。这确实需要认真审视我们现有的配置, 以及业务优先事项是否已发生转变——比如我们是否已将大量本地部署迁移到云端。显然, 网络安全支出也需要朝这个方向调整, 但我们也在努力尝试整合更多工具, 以便从我们目前使用的主要供应商那里获得更高性价比, 并尝试创造性思考。

我们是否需要专用的数据防泄漏工具? 还是说, 通过我们已有的端点网络和电子邮件安全工具, 就能覆盖80%的需求, 从而腾出预算, 用于更好的数据保护和用户行为分析类工具, 为业务内部的AI发展提供更坚实的数据保护基础?

PW: 你提到了几件事。第一, 随着迁移到云端, 你或许可以淘汰一些用于传统本地环境的工具。第二, 可能是供应商整合。

也许我们先从第一类开始, 你希望淘汰哪些工具? 是不是像本地身份管理这类工具, 比如PingID? 当迁移到云端后, 就转向云供应商? 我猜这是预算的重新分配, 并非真正节省资金, 而是从一个供应商转移到另一个供应商。是这样吗?

Kristie: 是的。对于这类只是跟随技术趋势的情况, 确实更多是转移。但正如我所说, 我们正努力进行更多整合, 尝试利用现有工具集上的更多功能, 或者通过添加模块来扩展能力——通常这比购买一个独立的专用工具要便宜得多。

而且, 假设代理程序已经部署, 你可能已经有托管服务或专门团队来维护它。因此, 通过这种整合努力, 我们可以实现一些削减和成本节约。这才是真正节省成本的地方, 从而腾出资金用于新的研究。

PW: 我想你提到了几个供应商类别。你说到了网络和电子邮件, 可能还有另一个, 在讨论DLP时提到的。

Kristie: 端点。

PW: 端点。这些是你试图将功能整合进去的核心领域吗? 还是还有其他领域?

Kristie：不。这三个基本构成了我们网络安全项目的基础，代表了进入我们环境的最大威胁向量。因此，这些工具是我们投入最多的领域，占我们预算和工具套件的大部分。

PW：如果你方便谈论具体供应商，我至少提几个。显然，有像Palo Alto这样传统上专注于网络安全的公司，以及CrowdStrike在端点领域。Palo Alto正试图变得更广泛，覆盖大多数领域，包括端点。不过，它在电子邮件安全方面目前似乎没有特别出色的产品。

像Palo Alto这样广泛覆盖的愿景有多吸引人？或者，微软是另一个很好的例子，它拥有几乎可以端到端覆盖的网络安全套件。你是倾向于坚持这些支柱，在每个领域都使用领先的供应商？还是可以想象尝试转向像微软或Palo Alto这样的单一供应商，以获得跨所有领域的服务？

Kristie：是的。我们今年实际上完成了微软的续约。因此，我们听取了微软关于Defender的推介，并进行了深入探讨。从性能角度来看，它无法与同类最佳工具相比，尤其是在那些特定支柱领域。当然，将所有东西整合到单一工具也存在不确定性，即把所有鸡蛋放在微软这一个篮子里，万一出现问题——类似于大约一年前CrowdStrike事件导致所有人蓝屏的情况。因此，在这些领域我们更倾向于多元化。

我们希望保持这三个支柱独立运作，代表各自领域的最佳实践，然后寻找机会，比如让我们的邮件安全提供商也能承担钓鱼培训，而不是单独使用一个独立的安全意识培训平台。也许我们的端点工具能提供更多功能……CrowdStrike的Falcon Exposure Management可以处理大量漏洞管理工作。身份安全也可以从它们一直在整合的平台中进一步扩展。这给了我们一些机会去做更多的工具整合。

PW：是的。你提到身份安全是其中的一部分，这很有意思。我刚刚和CrowdStrike的高管们聊过，他们认为身份安全……显然，他们有一些身份安全组件，但他们把身份安全视为一个独立的支柱。所以他们会寻求Okta或其他厂商来提供底层的身份基础设施。你如何看待身份安全在整个技术栈和支柱体系中的角色？你认为它可以被归入其中一个支柱，还是它本身就是一个独立的领域，但与其他支柱相互交叉？

Kristie：我认为，随着向远程办公的转变，以及“身份是新的边界”这种说法被广泛使用，身份安全确实需要独立存在。不幸的是，我接手的管理项目里有一个用于IGA的旧版身份工具，可能已经不再代表最佳实践了，而且它确实落后了，尤其是在管理非人类身份和一些对我们业务至关重要的其他关键功能方面。

所以，这可能是我们需要进行重大转型的领域，才能支持未来的业务发展。这也是一个领域，如果你有一个更强大的身份工具，它还能……目前，我有独立的MFA工具、独立的PAM工具和独立的EPM工具。所以，如果我能建立一个更好、更强的身份基础，我就可以开始将其中一些功能整合到一个单一的身份平台中，而不再依赖目前这些零散的工具。

PW：嗯，我以前的老板，现在在SailPoint负责产品，听到有人正在寻求该领域的最佳实践，一定会很兴奋。Sean，把最好的留到最后，对吧？我们想听听你所在组织的预算讨论是如何演变的。你们是怎么拿到这些资金的？因为听起来你们有实质性的增长。这些资金从哪来，为此需要付出多少努力？

Sean：主要是和CFO在博弈，因为我身兼两职。我是公司的CIO。所以在预算方面，这确实有点帮助。我说大概增加了12%。其中很大一部分将来自IT基础设施方面的重新分配，因为我们正在从传统架构迁移到AWS。

我们不会补充一些岗位，所以通过淘汰不需要的旧平台或转向开源工具来节省资金，从而抵消了这部分增长。我们的总支出净增了大约5%，但安全方面的支出增加了约7%。这部分是从基础设施方面转移过来的。我们利用AI启用的自动化工具来支付这笔费用。考虑到过去一年我们为这方面的成功所做的所有工作，我认为这很容易实现。

PW：所以，实际上，在你CIO的职责范围内，有一些来自旧系统的内部重新分配。除此之外，你还能从CFO那里获得自上而下的增量预算吗？还是说大部分资金都被限制在你CIO的预算范围内？

Sean：是的。这属于CIO的预算范围，但我们今年获得了大约5%的增长。然后我们只是在调整平衡，以确保我们能够满足当前的安全需求。因为我们发现了差距，并根据我们正在部署的自动化和开源工具，决定重新分配这些资金。

PW：就网络安全支柱而言，你把大部分增量资金投向了哪些领域？

Sean：对我们来说，其中一部分实际上是邮件，因为我们运行的是一个混合系统。我们运行多个系统。所以我們正在努力提高这方面的可见性，但与此同时，我们也在内部开发一些端点工具，因为我们在 DLP 方面有所欠缺。

我认为，每次我们从 DLP 的角度审视一个工具时，都发现非常困难，至少在保险行业是这样，因为我们拥有的数据元素很复杂。误报太多了。我们尝试过两种不同的工具，花了很多钱，但始终无法达到对我们有价值的程度。所以我们决定内部开发。所以，目前大部分资金都

投向了 DLP。

PW：这是你们必须内部构建的东西。弱点是什么？显然，有很多不同的供应商都在试图说，嘿，DLP 是其中的一部分。你提到了邮件。显然，邮件供应商有。你看看安全服务边缘，他们也会告诉你他们有。与现有供应商合作有哪些局限性，迫使你们不得不自己承担这项工作？

Sean：是的。我们就是无法以一种能够让我们对数据情况进行良好报告的方式来建模数据元素。误报太多了。我们在两种不同的工具上花了几个月的时间，但始终无法达到可用的程度，所以我们决定内部开发。我们构建了一个代理平台，现在部署在我们所有的端点上，这让我们能够完全控制如何在其他端点保护之上监控端点。所以我们混合使用了 Sophos 和 CrowdStrike。

所以我们运行了几种不同的东西。我们喜欢用多层方法来处理安全问题。但这让我们能够自定义在端点上看到的内容。我们可以看到端点上发生的所有事情，一直到内核级别，并且我们可以在端点监控器内设置相关规则。目前来看，这对我们来说是最合适的短期方案。现在，我们仍在寻找其他工具，同样是在 AI 方面，但我们还没有找到真正适合我们部署的工具。

PW：如果你按照 Kristie 的思路来思考，她围绕几个支柱来考虑网络安全。她提到邮件和通信、端点网络、身份安全是他们研究并正在整合的核心支柱。这个策略与你思考的方式有多一致？你的做法有什么不同吗？

Sean：不。差不多就是这样。我们这边用的是 Okta。我们已经用了四年了。很棒的产品。它确实让我们的安全工作轻松了很多。我认为，考虑到他们支持的所有工作流程和其他功能，这对我们来说是一个巨大的改变。这是一个很棒的产品。但我认为她提出的支柱以及我们的处理方式都是正确的。

PW：有意思。既然你提到了 Okta，身份安全这个领域现在似乎正迎来高光时刻，围绕构建代理带来的新复杂性，我们该如何处理身份问题，存在很多疑问。就你们而言，可能有一个面向客户的应用程序，因此客户也能访问代理和应用程序。你如何看待这一演变？因为，至少从目前讨论的各种说法来看，显然 Okta 同时处理客户和员工身份。他们有一个更广泛的平台，你可以使用他们的 PAM 和 IGA 解决方案。但也有像 CyberArk 这样的公司试图论证，你需要一个专门构建的、类似 PAM 的解决方案，来实现最小权限访问和与代理的可组合密码访问。还有大量初创公司，都在以不同的方式处理这个问题。GenAI，无论是从客户使用你们的工具，还是你们内部使用工具的角度，如何改变了你对身份安全的看法，以及你认为未来可能需要如何演变？

Sean：是的。这是个好问题。我们仍在努力解决这个问题。我们确实有几个正在开发的平台，但仍在部署中。我们正在处理我们看到的安全问题，以及如何在客户端系统中部署代理并在身份侧进行管理。我们确实运行着一个 PAM，但同样，这只是针对大多数人。我们企业里的每个人都有令牌，对吧？所以我们在整个企业中使用 YubiKeys。基于软件的 MFA 对我们来说问题重重。我们在那方面受到了很多攻击。所以我们决定改用 YubiKeys，这对我们来说效果不错。但是，是的，我认为我们仍在努力解决。随着工程团队构建这些平台，这是一个不断变化的目标。我们目前还无法判断该朝哪个方向前进，因为即使我们试图推出一些东西，我们也不知道它们最终会走向何方。

PW：嗯，我认为这可能是进入对话下半部分的好方式，我想我们想谈谈因 AI 而变化的 IT 需求。我想我们或许应该把讨论分成两个方面。一方面是攻击的速度和复杂性不断提高，以及相关的不确定性。我半开玩笑地把 Mythos 放进了这份报告的标题，但显然 OpenAI 推出了 Daybreak。没有人愿意落后，声称他们的工具可以被用来攻击任何人。所以这是入站方面，但另一方面还有你们的内部基础设施。也许从你们组织在采用 AI

方面的进展开始会很有帮助，这可以作为理解应对该不确定性所需的网络安全足迹的背景。

Sean：是的。所以我们有两个不同的部分。有工程人员。显然，他们利用 Codex 和代码，这带来了一定程度的向量复杂性。然后还有一般的运营人员和行政人员。我们将他们分开。基本上，我们在不同的租户上运行他们，这样我们可以维护他们并拥有更多控制权。从我的角度来看，从整体部署来说，我们仍处于初期阶段。工程方面遥遥领先，对他们进行治理一直是一个挑战。没有一个工程师喜欢在他们的机器上安装任何端点或类似的东西。这有时会令人沮丧，但他们最终会有所妥协。

PW：你们是否在桌面上使用 Copilot 或类似微软的产品？

Sean：是的。所以我们使用所有模型。我们让所有团队都能使用这些模型。现在，工程师们又是分开的，但我只是说普通员工。他们现在可以访问这些模型，但我们通常不允许他们全部使用四个。他们必须有业务案例，根据他们要做什么，我们会分配给他们 Copilot、ChatGPT、Gemini 或 Claude。但 Claude 在过去两个月里绝对是领跑者。我会说 90% 的请求都是针对 Claude 和 Cowork 的。他们的集成确实让他们与众不同。他们有 HubSpot、Office 365、Monday，所有 MCP 连接器都很棒。每个人都想要它们。我们遇到的问题是，显然，是令牌使用量。这个数字一直在上升。我们在 3 月 28 日达到了 Claude 的限额。到了 6 月，我们在 6 月 3 日就达到了限额。所以增长得这么快。但我们的用户数量只增长了大约 30%。所以，随着用户对这些工具越来越熟练，他们正在构建技能和代理，他们正在做所有这些事情。然后他们说，嗯，我收到一个警报说我的令牌用完了。但另一方面，在安全方面，我们正试图弄清楚，他们在提示什么？他们在做什么？输出是什么？目的是什么？他们只是在创作艺术品吗？对公司的回报表现率在哪里？我认为我们还没有看到这一点。

PW：你们是怎么做的？如果我听供应商的话，如果你去找 Palo Alto、CrowdStrike 或 Zscaler，他们每个都在谈论在桌面上有一个运行时代理，无论是 Prisma AIRS、CrowdStrike 收购的 AIDR，还是 Zscaler 内部引入的 Red Canary。你认为这是你需要走的方向吗？你如何看待处理评估从提示到能够掌控这一切的问题？

Sean：是的。我们将在我们的环境中部署一个 AI 路由器，所以所有人员基本上都会通过那个门户。这让我们能够在令牌使用、LLM 方向和提示监控方面拥有我们感到满意的良好控制水平。

然后，显然，从成本角度来看，我们运行一些本地 LLM。有些人只需要本地 LLM。他们不需要 Claude。他们不需要 Fable。这取决于具体情况。所以我们正在部署这些。我们一直在测试。它们运行得很好，我认为这将使我们能够对工具的使用方式有非常好的监督和治理。

PW：是的。每次推理花费 1/20 或 1/30 是相当不错的。

Sean：嗯，这就是优步，对吧？他们的 AI 预算用完了。这很好，但是，再说一次，回报表现率在哪里？如果你在每月的第三天就用完了令牌，而且我们看到 AI 模型的补贴正在下降，那么除非成本继续下降，否则这场盛宴将会结束，我们拭目以待。显然，采用速度要快得多。

PW：那么，至少现在，听起来像是一个中心辐射模型。所以你是在路由器层面，而不是真正使用一些我之前提到的概念，比如 Palo Alto 或安全服务边缘。

Sean：是的。我们目前还没到利用这些工具的阶段。我们考察过一些工具，但根据目前的预算来看，成本过高。不过，说到明年的 IT 支出，我们整个组织不会再签任何超过一年的合同了。我们的 PDF 供应商，我们只签了一年，因为我不确定明年是否还需要它。终端安全也一样。我们刚刚续约了 EDR 解决方案，但也只签了一年，因为我不知道明年的情况会怎样。那个产品可能不再适用，我不想被锁定在三年期的合同里。

PW：有意思。你提到这个，让我想到一件事……我本来没想深究这个话题，因为我想先聊别的，但 EDR 供应商给人的印象是，由于你构建的所有定制化、规则和配置，存在大量的供应商锁定。不过，听你刚才的描述，似乎重新考虑更换 EDR 供应商这件事，比想象中更容易实现。这有多现实？更换供应商的能力如何？

Sean：是的。好吧，如果你有成千上万个端点，并且长期深陷于某个工具，没人喜欢进行“叉车式”迁移。但归根结底，现实已经改变，而且每天都在变。所以，如果必须做，我们就会去做。我们必须做到100%正确，但我们做不到。因此，在这方面，我们必须保持灵活。如果有更好的工具能够满足需求，即使贵一点，我们也得朝那个方向走。

PW：是的。Kristie，也许我们可以接着Sean刚才提到的几个不同方面来聊。你不太属于CIO那一侧，所以可能对合同期限的看法少一些，但听听你从网络安全角度的看法也会很有趣。不过，我更想从更广泛的背景来看，AI是如何被组织采用的，或者它如何改变了你对攻击者入侵不确定性的看法？

Kristie：是的。Sean刚才说的几点，我想评论一下。我们也看到了AI token使用量的同样增长。实际上，我认为微软Copilot从6月1日开始进行了一些重新分类，这对我们打击很大。同样，我们的工程师在三天后回来，说他们没有剩余的token来完成工作了。因此，我们正在考虑做更多事情，尝试通过Llama模型启用更多的本地LLM，给他们提供编码的机会，但我们可能得升级很多笔记本电脑，才能在单个设备上获得运行大型语言模型所需的算力，而不仅仅是那些较小的模型。这是我刚才想补充的一点。但回到你的问题，关于我们如何准备……你能再重复一遍吗？

PW：好的。我想其中一点是，听起来你们已经为开发者和业务人员都部署了Copilot。你们如何考虑保护这些工具，监控输入到提示词中的内容，确保商业机密不被泄露，以及防止操作不当？我想我们可以从这个方面开始聊。

Kristie：是的。我们构建了一个AI安全框架，目前正在基于此开展工作。我们确定了希望在端点、网络、数据、身份以及产品侧的DevOps环境进行研究的领域。可能比较容易的一些方面……端点和网络实际上只是审视我们现有的工具。从这个意义上说，我们是CrowdStrike和Zscaler的用户。它们有产品可以用来评估人们正在使用的提示词。从数据安全的角度，我们也在考察Varonis，目前我们还没有这个，目的是为了更好地了解人们用它来做什么。他们如何使用它？输入了什么数据？我们如何保护它？然后，在接收端，从我们的环境返回给他们的数据是什么？他们是否拥有访问和权限来实际查看这些文件？所以，我们再次从这些主要层级进行审视。

PW：是的。听起来，对于端点，你们要么通过Web安全（Zscaler的视角）来审视，要么通过端点视角来审视，这与Sean的做法有些不同，他更多是采用中心辐射型模式，在token路由层面进行管理。在设备上运行这种运行时安全有什么吸引力？你们如何在安全服务边缘（SSE）的能力和端点代理的能力之间做出决策？

Kristie：是的。我认为CrowdStrike能让我们在端点层面看到存在哪些影子AI，人们在自己的本地机器上安装了什么东西。他们是否在本地进行数据外泄？他们是否有任何未经授权的工具或浏览器扩展，可能被用来直接从设备窃取数据？然后，任何内部AI操作工具、MCP、不当的提示词管理等，这类事情都可以通过端点上的CrowdStrike来发现。而Zscaler的网络安全则更多是针对不受控制的外泄，即数据在未经检查或未经DLP的情况下离开环境。

PW：我记得你之前提到过，你们还有一个网络安全支柱，但听起来你们并没有使用像Palo Alto的Prisma AIRS这类产品。那不是你们考虑的方向。你们更侧重于安全服务边缘和端点。所以，这实际上更紧密地围绕着用户代理和最终用户。

Kristie：是的，完全正确。我们希望它更侧重于单个用户，因为公司业务范围很广，对吧？试图管理那么多人，试图管理token如何在25000名知识工作者之间路由……这非常具有挑战性。

因此，实际上必须建立可以在整个组织内应用的防护栏，这样无论他们使用什么工具，部署了什么LLM，批准了什么SaaS工具，都能得到保护。因此，我们仍然独立于业务所采用的AI方向来管理我们的数据。

PW：当然。这说得通。由于更多的入站不确定性，你们不得不如何改变网络安全态势？无论是来自应用安全攻击层面的不确定性，比如Mythos或Daybreak，还是来自钓鱼攻击和各种其他攻击，其复杂性和数量都在增加。

Kristie：是的。所以我认为我们基本上是在沿着这个思路，对整个工具栈进行现代化改造。目前，我们的安全运营中心完全外包给了一家MSSP，我们正考虑将其切换为一个智能体SOC，或者大幅补贴该中心，使其能够在Mythos时代以机器速度运行。当平均利用时间只有四分钟时，三到四小时的分类时间是不可接受的。因此，你需要能够更快地运作。这是我们短期内正在做出改变的领域之一。这也是我们将进行研究的领域。

PW：你们打算怎么做？显然，市面上有像Torq这样的初创公司，但也有你之前提到的那些供应商，比如CrowdStrike推出了Charlotte，还有其他一些。你们如何看待这个智能体SOC，你们会在哪里引入这些智能体，谁又能很好地支持你们？

Kristie：是的。目前，我们正在考察Torq和Prophet。看起来，至少开箱即用的话，Prophet的功能更强大。Torq可能可定制性更强，但我们不一定有人力去构建所有的剧本。我们需要的是更接近开箱即用、能直接基于MITRE ATT&CK框架和最佳实践运行的工具。所以我们最终可能会选择类似这样的工具，来帮助我们以那样的速度运作。

PW：那么，为什么选择初创公司，而不是选择CrowdStrike或一些由现有供应商构建的方案呢？

Kristie：老实说，是因为现有供应商的方案显得很笨重。他们是在自己的传统平台和技术上构建的，其本身并不一定是为了成为一个独立的智能体AI而构建的。看起来他们并不一定拥有同类最佳的能力。所以我们试图保持其独立性，这样我们仍然能享受CrowdStrike在端点提供的保护优势，但决策是由另一个不同的工具来完成的。这也提供了更大的灵活性。CrowdStrike在集成所有这些其他工具以摄取所有数据方面并不那么出色。因此，基本上，将其推给像Prophet或Torq这样的第三方更容易。

PW：是的。我也听说了这一点。Torq或Prophet的“瑞士”属性……它们在这个领域是天然合适的选择，因为它们需要跨多个网络安全支柱工作，而信任其中一个支柱的供应商效果并需要继续观察。

Kristie：是的。

PW：Raj，我知道我们时间不多了，但AI是如何影响你们必须考虑保护的那些技术的，无论是Copilot还是用于智能体SOC的AI应用？

Raj：在过去的几年里，我们不得不审视我们现有的工具，并在很多领域对其中许多工具进行了增强。所以我认为，就我而言，情况与Sean所说的类似。我们遵循中心辐射模型，试图在企业层面实施治理。因此，在过去几年里，审视组织内部发生的所有AI计划，我们部署了几个专门用于AI监控的工具。我们有一个工具，不知道大家是否熟悉，叫Aim Security。今年早些时候，这家公司被Cato Networks收购了。它本质上就是我们的AI提示监控和防火墙平台。我们用它来确保当人们从我们的内部应用程序与公共大语言模型交互时，不会发生数据泄露、提示注入或提示工程。

PW：顺便问一下，关于这个，你们是更广泛地使用Cato Networks，还是只使用他们收购的那个产品？

Raj：不，只用那个产品。事实上，完全透明地说，随着市场的发展，我们未来可能会寻找其他更全面的替代方案。但是，去年，那是市场上比较成熟的产品之一。所以我们签约了，它正在实现最初的目标。然后，在智能体SOC方面，我们实际上使用的是Tines。我们是Tines的用户。Tines与Torq非常相似，他们正在围绕智能体SOC能力和自主响应进行一些创新。我们现在正在测试这个。我认为最大的障碍是让业务部门接受自主响应。因为有时可能会出现误报，导致某个服务器或服务被隔离。所以我们正在进行这些对话，并确保我们正在微调我们的内部策略和自主响应。最后，和其他人一样，我们有CrowdStrike。我们有Wiz。我们还有其他也具备自主响应能力的工具。因此，我们开始在特定领域利用这些工具，以确保我们能够应对这些以机器速度发生的攻击。

PW：你们是否使用Tines来协调所有这些工具，就像智能体与智能体对话一样？你们如何并行使用多个不同的智能体平台？

Raj：目前，在网络防御智能体方面，Tines是我们使用的唯一具备智能体能力的工具。我们所做的是，将所有其他产品和解决方案的信号和告警流式传输到我们的SIEM。我们实际上部署了Cribl，如果你熟悉Cribl的话。它提供实时的日志流。其中一部分由Tines监控，我们在Tines中构建了策略和用例，基于这些用例，如果Tines中的智能体进程发现需要自主响应或升级处理的情况，它就会触发工作流。

PW：我知道我们只剩下几分钟了，所以在结束之前，也许我们可以快速进行一轮快问快答。Raj，因为你一直和我们在一起，我先问你。今年给你印象最深的三个供应商是哪几家？为什么？也许另一边，哪些供应商让你失望？

Raj：好的。我认为Wiz是我们的关键支柱之一。我们是一个混合环境。我们有一个相当大的云平台。Wiz一直是一个很好的合作伙伴，他们所做的一切以及他们提出的新创新和功能都非常出色。CrowdStrike多年来一直是我们的安全计划的中流砥柱，所以我们非常依赖它。然后，最近，Palo Alto在推出诸如智能体注册表、MCP网关以及我们在企业层面寻找的那些能力方面做得相当不错。

PW：在谨慎方面，最近谁让你失望了？

Raj：我想可能只有一个，微软。我们与微软进行了很多沟通。他们的解决方案、概念和路线图在纸面上看起来不错，但在实施和测试过程中，它们并没有真正达到预期。我认为他们还需要一些时间才能达到顶尖水平。

PW：Kristie，同样的问题。今年给你留下深刻印象的两三个供应商是哪些？

Kristie：是的。我想换个方向，我同意 Raj 的说法，但我们一直在考察许多初创公司来满足部分需求。所以我们正在评估 Remedio 用于漏洞管理和补丁管理配置。我们正转向 Frame 进行安全意识培训和钓鱼培训。他们能制作大量非常优质的 AI 生成快速定制培训视频。

PW：你们之前用的是 KnowBe4 还是别的？之前是什么情况？

Kristie：是的。我们打算从 KnowBe4 切换到 Frame。

PW：你提到的第三家供应商是哪家？

Kristie：我想重申一下 CrowdStrike。我认为他们在这个领域一直是很好的合作伙伴，而且他们在研究和能力建设方面相当有活力。但问题在于，每样东西都变成了另一个模块、另一个附加组件、另一笔开销。这让人很沮丧。

PW：明白了。所以这更多是谨慎评价，对吧？

Kristie：是的。另一个表现不佳或令人失望的供应商是 Proofpoint。我认为他们在过去几年没有进行足够的研究来保持行业顶尖水平。所以未来几年他们会如何发展，值得关注。此外，我们的身份提供商是 One Identity。五年前他们在正面竞争中胜出，成为我们环境中的最佳解决方案，但现在已经停滞不前，完全掉队了。与他们合作也充满挑战。

PW：你觉得你们可能会转向哪家？

Kristie：可能是 Saviynt、SailPoint，甚至 Pathlock，任何更侧重于管理非人类身份、管理固有职责分离等正常业务运营中固有问题的方案，而不仅仅是处理人员变动、入职和离职。

PW：好的。Sean，今年谁给你留下的印象最深？

Sean：我会说是 Okta 和 CrowdStrike。他们跟上了节奏。这是我最近真正讨论过产品变化的最后两家公司，他们做了该做的事。令人失望的是

7AI。我和他们谈过，产品看起来确实很棒，但他们完全无法控制成本。我们拿到报价后，成本是我们预期的 10 倍。这完全不合理。另一个是 Zenity。它看起来也不错，但我认为他们没有全面考虑 Agentic AI 的整体图景。他们肯定存在一些漏洞，而且无法给出答案。所以我认为，这仍然是一个不断变化的目标，每个人都想回答所有问题，但做不到。我觉得很多公司摊子铺得有点太大了。

PW：感谢各位。非常感谢你们的参与。我知道我们超时了几分钟。各位听众，如果有任何问题，请随时联系我。我很乐意进一步讨论这些话题。各位，我期待未来继续我们的对话。